Sécurité des systèmes informatiques

La cryptographie

Abdeltouab Belbekkouche

a.belbekkouche@umontreal.ca

Université de Montréal

Contenu

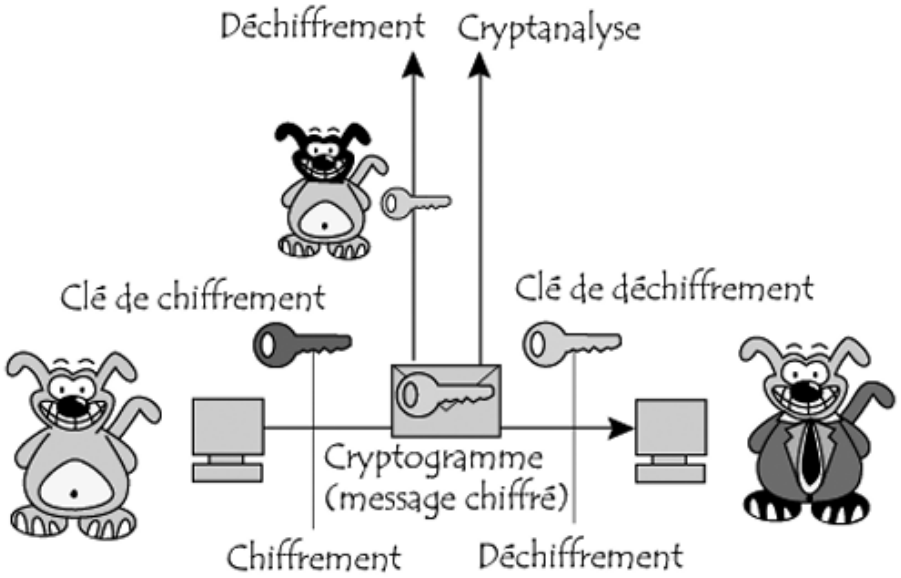
- Cryptographie
- Algorithmes de hachage
- Cryptographie symétrique
- Cryptographie asymétrique
- Cryptographie quantique
- Stéganographie

Cryptographie: définitions

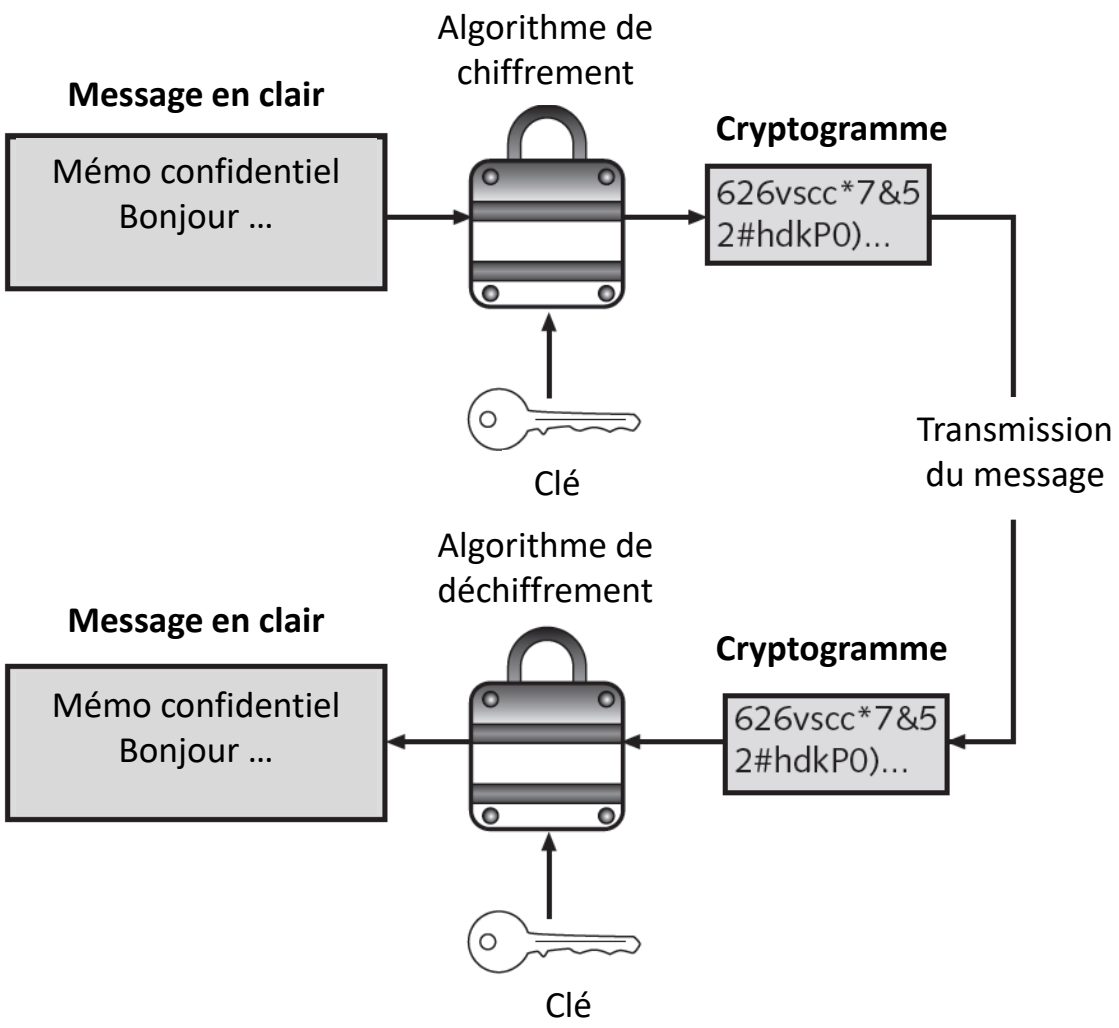
- Mots grecs : *kruptos* et *graphein* (caché et écrire)
- Terme générique qui désigne l'ensemble des techniques permettant de chiffrer (crypter) l'information pour la rendre inintelligible (incompréhensible)
- La science de la transformation de l'information dans un format sécurisé pour qu'elle puisse être transmise et stockée sans que les personnes non autorisées ne puisse y avoir accès
- Origines
  - Jules César (100 - 44 av. J.-C.)
    - Décaler chaque lettre alphabétique trois positions dans l'alphabet : A ➔ D, B ➔ E, etc.

Cryptographie: définitions (suite)

- **Chiffrement** (*Encryption*)
  - Changer le texte d'origine en un message secret en utilisant la cryptographie
- **Déchiffrement** (*Decryption*)
  - Transformer le message secret dans sa forme originale
- **Message en clair** (*Cleartext / Plaintext*)
  - Données stockées ou transmises sans chiffrement
  - Données à chiffrer
- **Cryptogramme** (*ciphertext*)
  - Message chiffré
- **Clé** (*key*)
  - Valeur mathématique utilisée par l'algorithme de chiffrement pour produire une message chiffré ou un cryptogramme (*ciphertext*)
  - Utilisée par le processus inverse pour le déchiffrement



Cryptographie: définitions (suite)



Cryptographie et sécurité

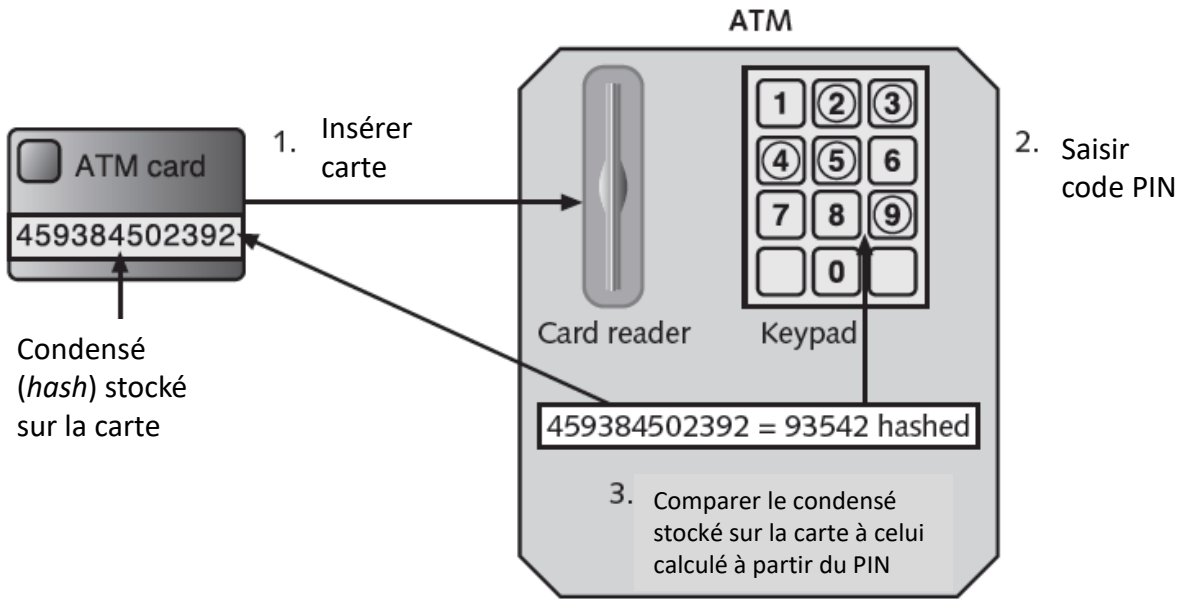
- La cryptographie protège l'information en fournissant
  - **Confidentialité**
    - Seulement les entités autorisées peuvent la consulter
  - **Intégrité**
    - S'assurer que l'information est correcte et non altérée
  - **Disponibilité**
    - Les utilisateurs autorisés peuvent y avoir accès
  - **Authentification** de l'émetteur
  - **Non répudiation**
    - Prouver que l'utilisateur a effectuer une action

Algorithmes cryptographiques

- Catégories
  - Algorithmes de hachage
  - Algorithmes de cryptographie symétrique
  - Algorithmes de cryptographie asymétrique

Algorithmes de hachage

- Le type le plus simple parmi les algorithmes cryptographiques
- Création d'un **résumé** (condensé ou *hash*) unique pour chaque message
- Le résumé ne peut pas être utilisé pour retrouver le message d'origine
  - Utilisé principalement pour des raisons de comparaison
- Exemple



Algorithmes de hachage (suite)

- Caractéristiques
  - Taille fixe
    - Les message courts et longs doivent produire des résumés de même taille
    - Exemple

Résumé d'une lettre	86be7afa339d0fc7cfc 785e72f578d33
Résumé d'un million de lettres	4a7f5723f954 eba1216c9d8f6320431f

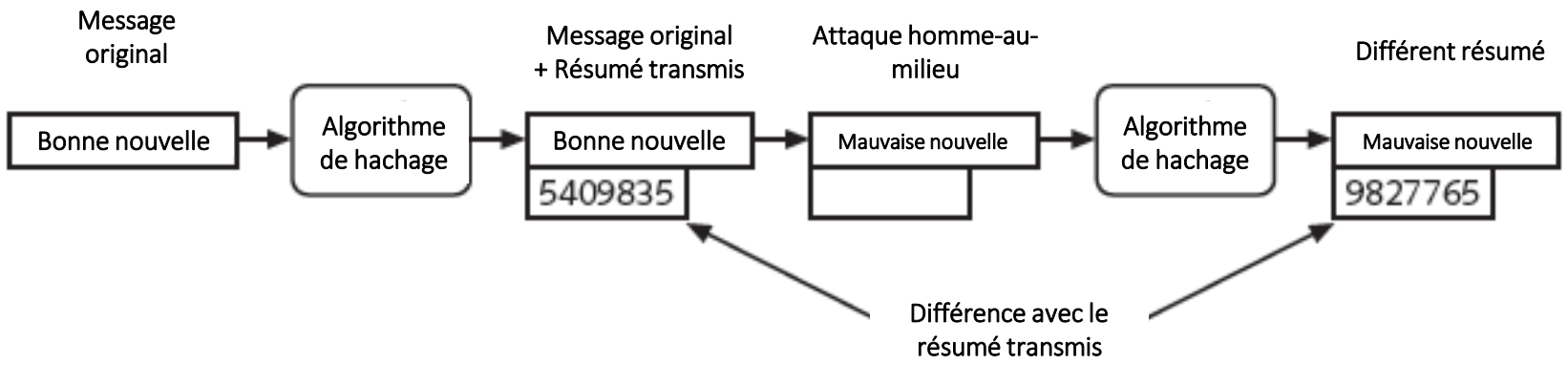
    - Deux message différents ne peuvent pas produire le même résumé (collision)
  - Original
    - On ne peut pas créer un message pour obtenir un résumé prédéfini
  - Sûr (*secure*)
    - Le résumé produit ne peut pas être renversé pour trouver le message d'origine

Algorithmes de hachage (suite)

- Fonction à sens unique : f
  - Facile à calculer $y = f(x)$ à partir de x, mais difficile à calculer x à partir de y
  - Exemples :
    - Deux grands nombres premiers, p et q. On pense que la fonction $f(p,q) = p*q$, est à sens unique
    - Soit n, un nombre composé. On pense que la fonction $g(x) = x^2 \bmod n$, qui calcule les carrés $\text{modulo } n$, est à sens unique

Algorithmes de hachage (suite)

- Utilisations
  - Déterminer l'intégrité des messages
    - Peut protéger contre les attaques homme-au-milieu (*man-in-the-middle*)
  - Authentification
    - Hashed Message Authentication Code (HMAC)
      - Le chiffrement du résumé fournit une sécurité améliorée
      - Utilise une clé secrète partagée entre l'émetteur et le récepteur
      - Le récepteur utilise la clé pour déchiffré le résumé
  - Sites de téléchargement
    - Vérifier l'intégrité des fichiers téléchargés



Algorithmes de hachage (suite)

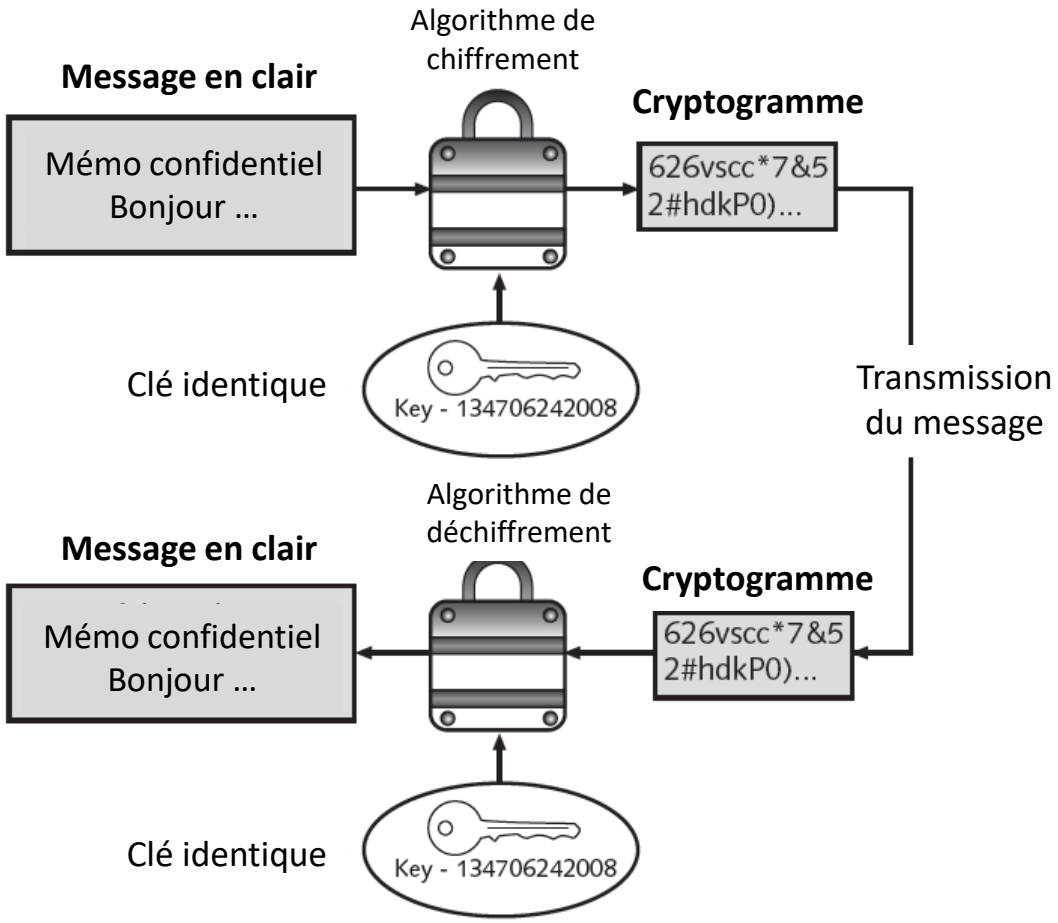
- Protections des algorithmes de hachage

Caractéristiques	Protection?
Confidentialité	Non
Intégrité	Oui
Disponibilité	Non
Authentification	Non
Non répudiation	Non

- Message Digest (MD)
- Secure Hash Algorithm (SHA)
- Whirlpool
- Race Integrity Primitives Evaluation Message Digest (RIPEMD)
- Mots de passe Windows: LM (LAN Manager) et NTLM (New Technology LAN Manager)
- Linux et Mac OS: MD5, SHA-256, SHA-512, SHA-1 avec une séquence de bits aléatoire ajoutée en entrée (*salt*)

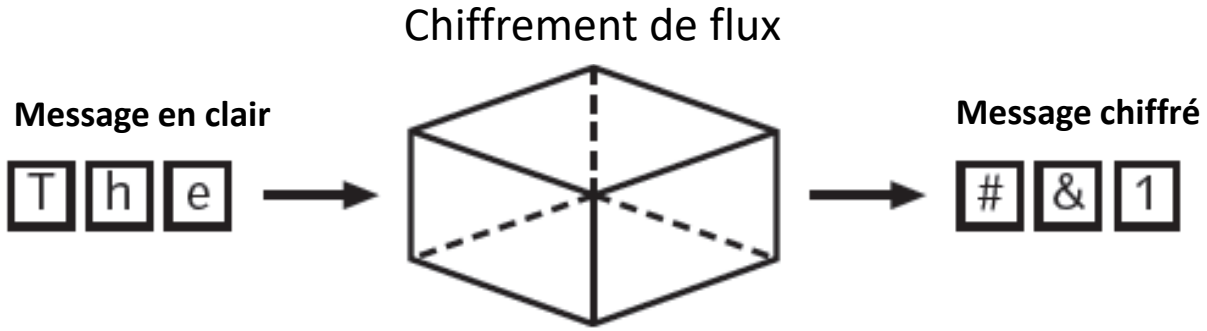
Cryptographie symétrique

- La même clé est utilisée pour le chiffrement et le déchiffrement



Cryptographie symétrique (suite)

- Deux catégories d'algorithmes, en se basant sur la quantité de données traitées à la fois
  - Chiffrement de flux (*stream cipher*)
  - Chiffrement par bloc (*block cipher*)
- **Chiffrement de flux (*stream cipher*)**
  - Remplacer chaque caractère à chiffrer par un ou plusieurs caractères
  - Avantage: rapide si le message à chiffrer est court
  - Inconvénient: consommation élevée de puissance de calcul si le message à chiffrer est long

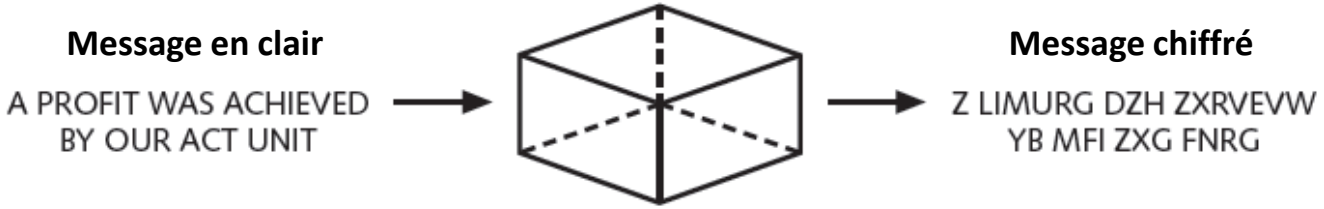


Cryptographie symétrique (suite)

- Chiffrement par substitution mono-alphabétique

A B C D E F G H I J K L M N O P Q R S T U V W X Y Z — **Plaintext letters**
Z Y X W V U T S R Q P O N M L K J I H G F E D C B A — **Substitution letters**

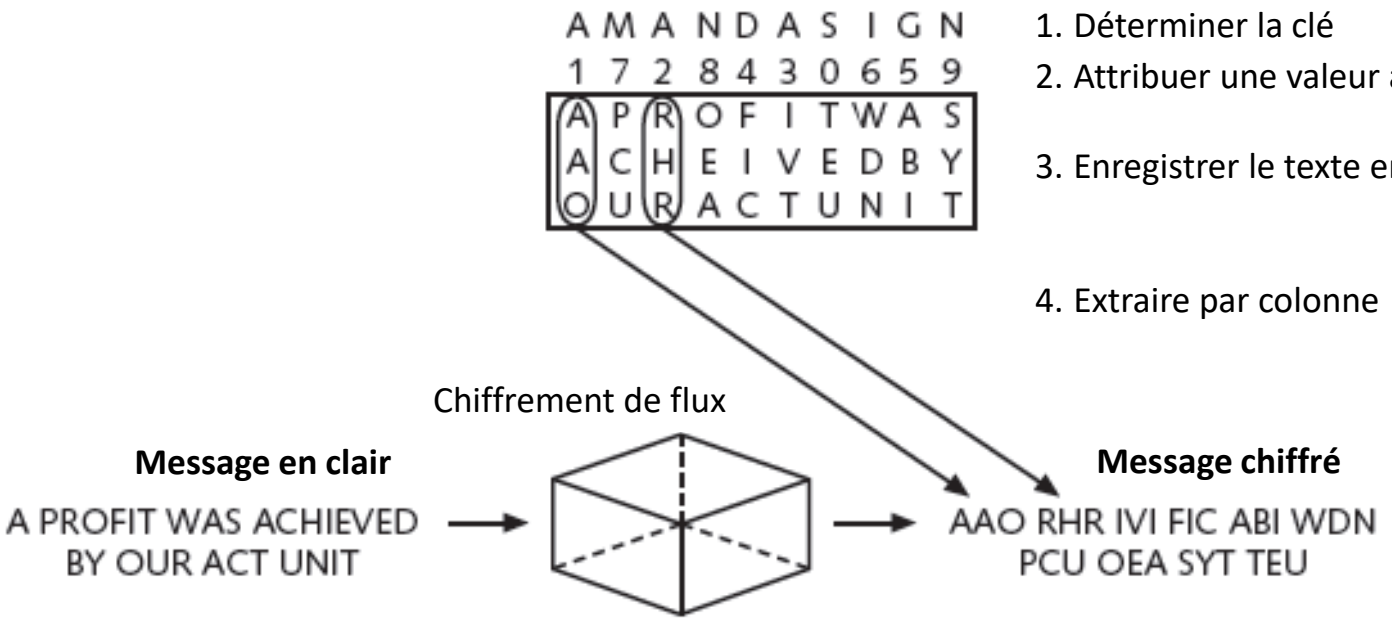
Chiffrement de flux



- Chiffrement par substitution homo-alphabétique
  - Substituer chaque caractère à chiffrer par plusieurs caractères
  - Exemple: A ➔ ILS

Cryptographie symétrique (suite)

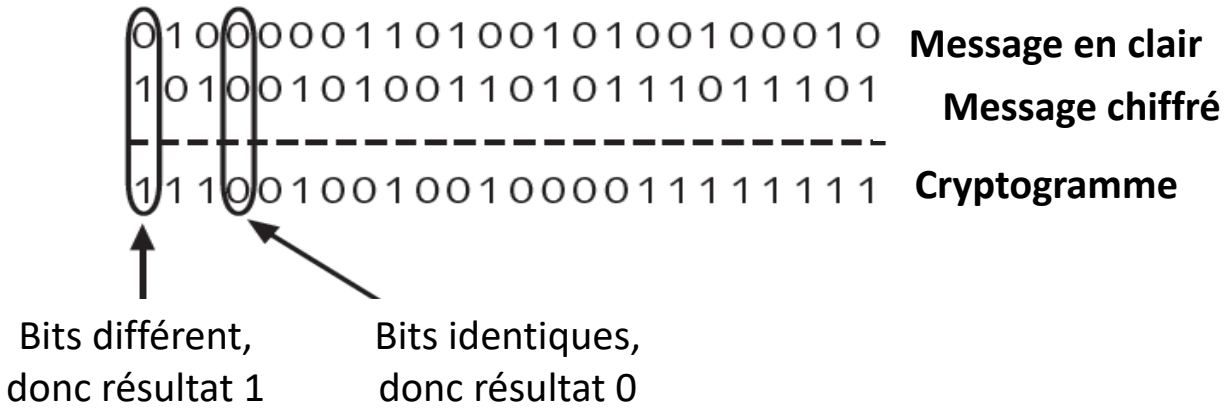
- Chiffrement par transposition
  - Réarranger les lettres sans les changer



1. Déterminer la clé
2. Attribuer une valeur à chaque position
3. Enregistrer le texte en clair par ligne
4. Extraire par colonne

Cryptographie symétrique (suite)

- Étape finale
  - Souvent le message en clair et le message chiffré sont combinés



  - Une clé aléatoire (*One-Time Pad*) peut être combinée avec le message en clair
    - Considéré comme sûr si la clé est aléatoire, gardée secrète et non réutilisée
    - Approche théorique!

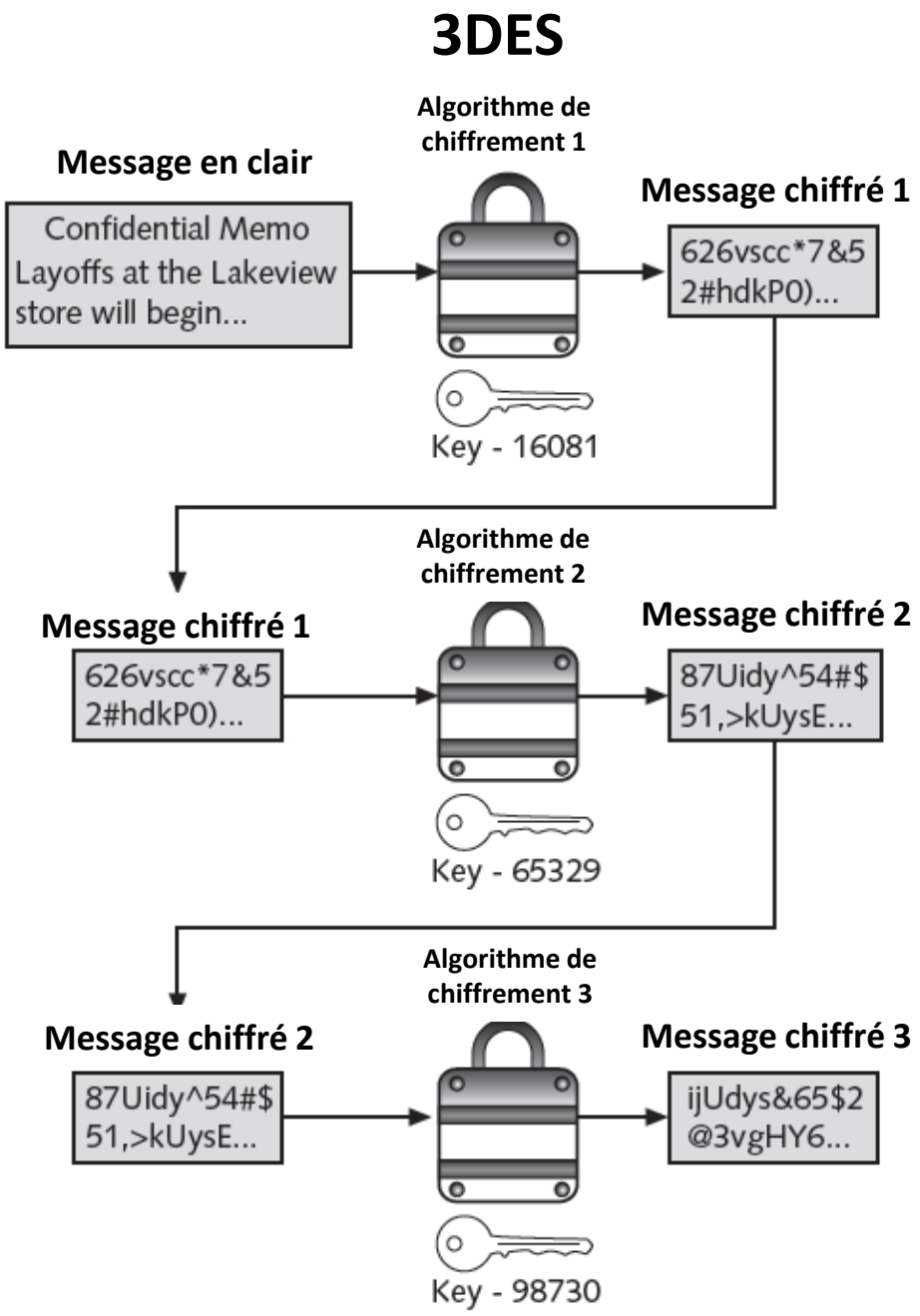
Cryptographie symétrique (suite)

- **Chiffrement par bloc**
  - Traite un bloc du message en clair à la fois
  - La taille des blocs varie de 8 à 16 octets (*bytes*)
  - Les blocs sont répartis de façon aléatoire pour augmenter la sécurité
  - Plus sécuritaire que le chiffrement de flux car le résultat est davantage aléatoire
- Protections offertes par la cryptographie symétrique

Caractéristiques	Protection?
Confidentialité	Oui
Intégrité	Oui
Disponibilité	Oui
Authentification	Non
Non répudiation	Non

Cryptographie symétrique (suite)

- Data Encryption Standard (DES)
  - Conçu au début des années 1970
  - Chiffrement par bloc (64-bits par bloc)
  - Clé de 56-bits
  - Il est déconseillé de l'utiliser aujourd'hui
- Triple Data Encryption Standard (3DES)
  - Remplace DES
  - Exécute trois tours (*rounds*) de l'algorithme de chiffrement
  - Le message chiffré de chaque tour redevient l'entrée du tour suivant
  - Utilisation d'une clé différente pour chaque tour d'exécution



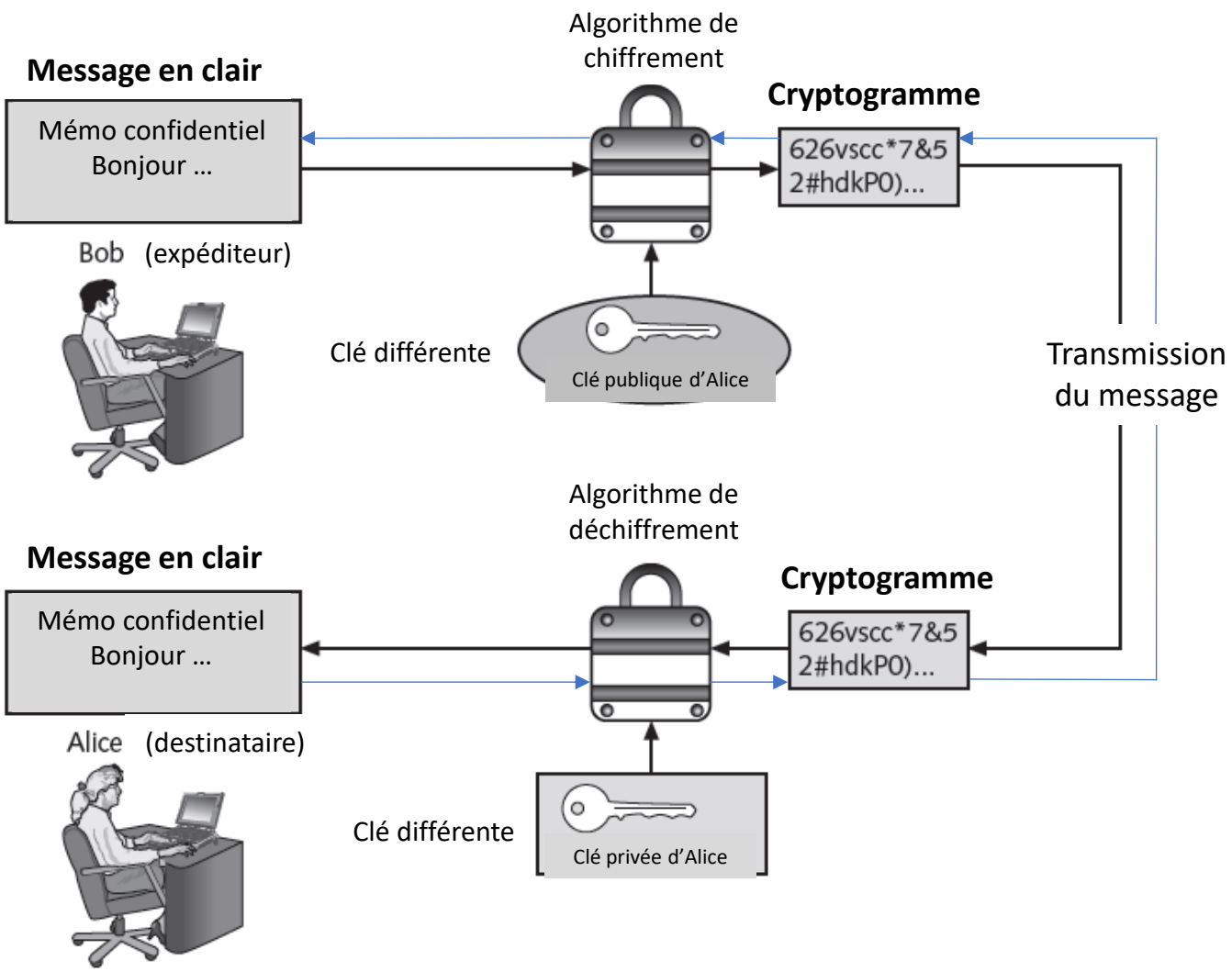
Cryptographie symétrique (suite)

- Advanced Encryption Standard (AES)
  - Approuvé par le NIST en l'an 2000 comme remplacement de DES
  - Standard de chiffrement officiel pour le gouvernement des É-U
  - Blocs de 128-bits et clé de 128-bits à 256-bits
  - Effectue trois étapes de chiffrement sur chaque bloc du message en clair
  - Conçu pour être sécuritaire bien dans le future
- Rivest Cipher (RC1 à RC6)
  - RC4: chiffrement de flux (128-bits) utilisé dans WEP (Wired Equivalent Privacy)
- International Data Encryption Algorithm (IDEA)
  - Conçu au début des années 1990s et utilisé en Europe
  - Blocs de 64-bits et clé de 128-bits avec 8 tours d'exécution
- Blowfish
  - Blocs de 64-bits et clé de 32-bits à 448 bits

Cryptographie asymétrique

- Faiblesse de la cryptographie symétrique
  - Distribuer et maintenir des pairs de clés pour un grand nombre d'utilisateurs géographiquement dispersés
  - Pour N utilisateurs désirant communiquer deux à deux: chacun d'entre eux doit posséder $N*(N-1)/2$ clés
- Cryptographie asymétrique
  - Cryptographie (chiffrement) à clé publique
  - Utilise deux clés mathématiquement liées
  - Une clé publique disponible à tout le monde
  - Une clé privée secrète connue uniquement par son propriétaire

Cryptographie asymétrique (suite)

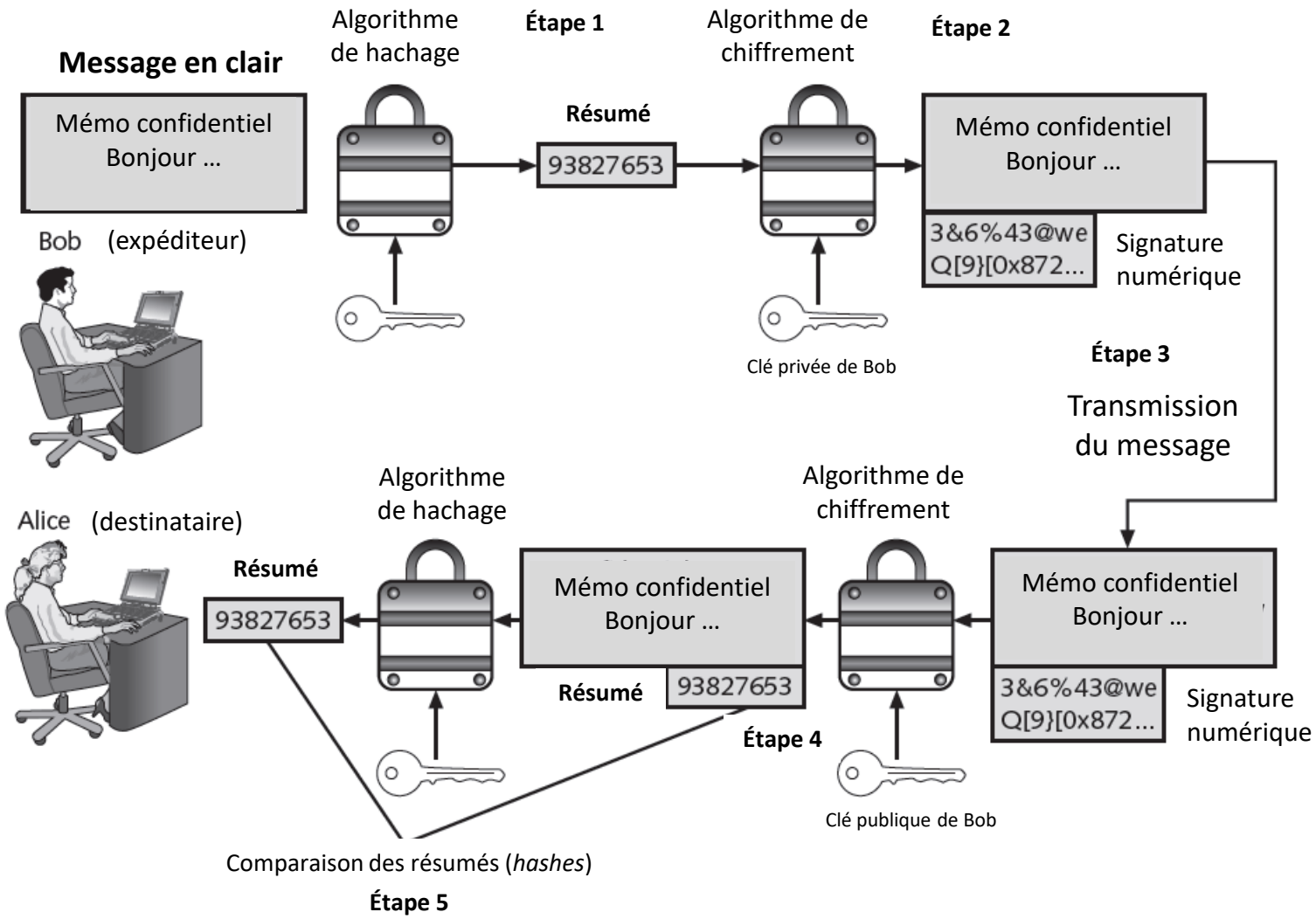


Cryptographie asymétrique (suite)

- Principes de base
  - Pair de clés
    - Clé publique
    - Clé privée
  - Deux directions
- Signature numérique
  - Vérifier l'émetteur
  - Empêcher l'émetteur de nier le message
  - Preuve d'intégrité du message

Cryptographie asymétrique (suite)

- Signature numérique



Cryptographie asymétrique (suite)

Action	À qui appartient la clé?	Quelle clé utiliser?	Explication
Bob veut envoyer un message chiffré	Clé d'Alice	Clé publique	Pour envoyer un message chiffré, la clé publique du destinataire est utilisée
Alice veut lire un message chiffré envoyé par Bob	Clé d'Alice	Clé privée	Un message chiffré peut seulement être déchiffré en utilisant la clé privée du destinataire
Bob veut envoyer une copie à lui-même du message chiffré qu'il a envoyé à Alice	Clé de Bob	Clé publique pour chiffrer Clé privée pour déchiffrer	Un message chiffré peut seulement être déchiffré par la clé privée du destinataire; Bob doit le chiffrer avec sa propre clé publique et puis utiliser sa clé privée pour le déchiffrer
Bob reçoit un message de réponse chiffré d'Alice	[illegible]	[illegible]	[illegible]

Université de Montréal

Cryptographie asymétrique (suite)

Action	À qui appartient la clé	Quelle clé utiliser	Explication
Bob veut que Susanne lit la réponse d'Alice qu'il a reçu	Clé de Susanne	Clé publique	Le message doit être chiffré avec la clé publique de Susanne pour qu'elle puisse le déchiffrer avec sa clé privée
Bob veut envoyer à Alice un message avec une signature numérique	Clé de Bob	Clé privée	La clé privée de Bob est utilisée pour chiffrer le résumé
Alice veut lire la signature numérique de Bob	Clé de Bob	Clé publique	Parce que la clé publique et la clé privée de Bob fonctionnent dans les deux directions. Alice peut utiliser la clé publique pour déchiffrer le résumé

Cryptographie asymétrique (suite)

- Protections de la cryptographie asymétrique

Caractéristiques	Protection?
Confidentialité	Oui
Intégrité	Oui
Disponibilité	Oui
Authentification	Oui
Non répudiation	Oui

Cryptographie asymétrique (suite)

- RSA
  - Publié en 1973 et breveté par le MIT en 1983
  - L'algorithme de cryptographie asymétrique le plus utilisé
  - Utilise deux grands nombres premiers

Étape		Exemple
1.	Choisir deux nombres premiers, **p** et **q**	**p = 7** et **q = 19**
2.	Multiplier **p** et **q** pour obtenir **n (n = p*q)**	**n = 7 * 19 = 133**
3.	Calculer **m = (p-1) * (q-1)**	**m = ((7-1) * (19-1) = 6 * 18 = 108**
4.	Trouver un nombre **e** tel que **e < n** et **e** et **m** sont premiers entre eux (leur plus grand commun diviseur est égal à 1)	**e = 5**
5.	Trouver un nombre entier **d** tel que **(e*d-1)** est divisible par **m** (c-à-d., **e*d modulo m = 1**) ou **d = (1+f*m)/e)**	**d = (1 + (3*108))/5 = 325/5 = 65**

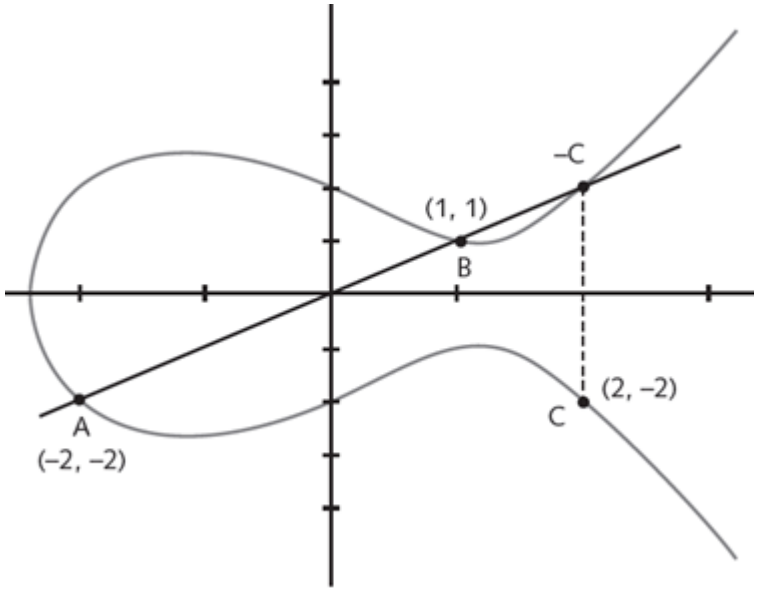
  - La clé publique est (n, e) **=** (133, 5) et la clé privée est (n, d) **=** (133, 65)

Cryptographie asymétrique (suite)

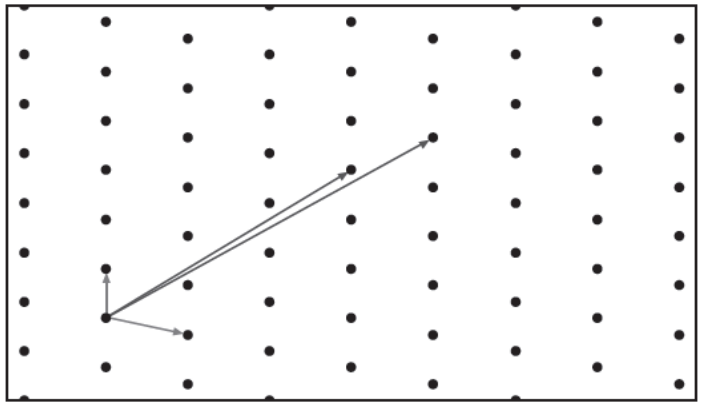
- RSA (suite)
  - Pour chiffrer le message en clair **a** et produire un message chiffré **c**:
    - $c = a^e \ mod(n)$
    - $c = a^5 mod(133)$
  - Pour déchiffrer le message **c** et obtenir le message en clair **a**:
    - $a = c^d \ mod(n)$
    - $a = c^{65} \ mod(133)$
  - Inconvénient
    - Lenteur: DES est ~ 100 fois plus rapide sur logicielle et entre 1,000 et 10,000 sur matériel

Cryptographie asymétrique (suite)

- Système à courbe elliptique (*Elliptic curve cryptography,* ECC)
  - Problème du logarithme discret sur des courbes elliptiques
  - Utilisation des points d'une courbe elliptique
  - Nécessite moins de puissance de calcul que RSA
  - Intéressant pour les composantes mobiles

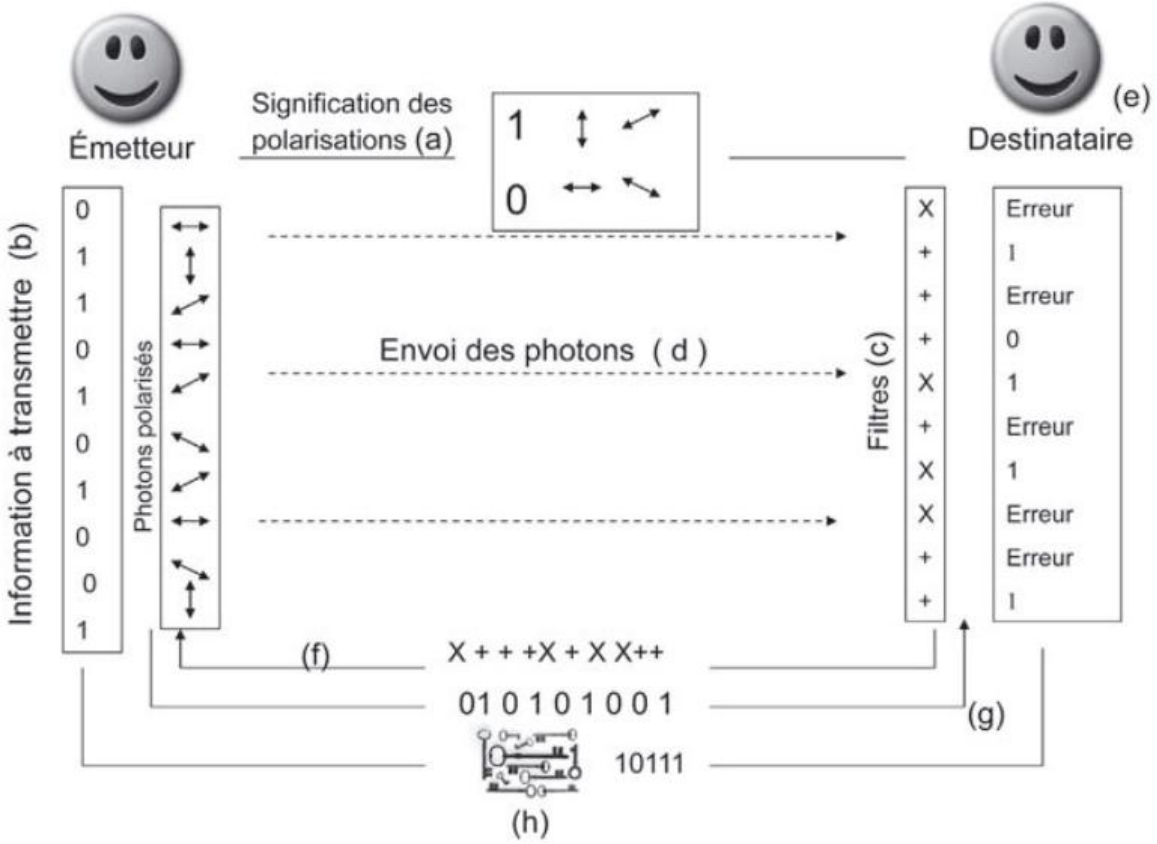


- NTRUEncypt
  - Basé sur des ensembles de points dans l'espace (réseaux) et sur le problème du plus court vecteur
  - Plus rapide que RSA et ECC
  - Résistant aux attaques qui utilisent le calcul quantique



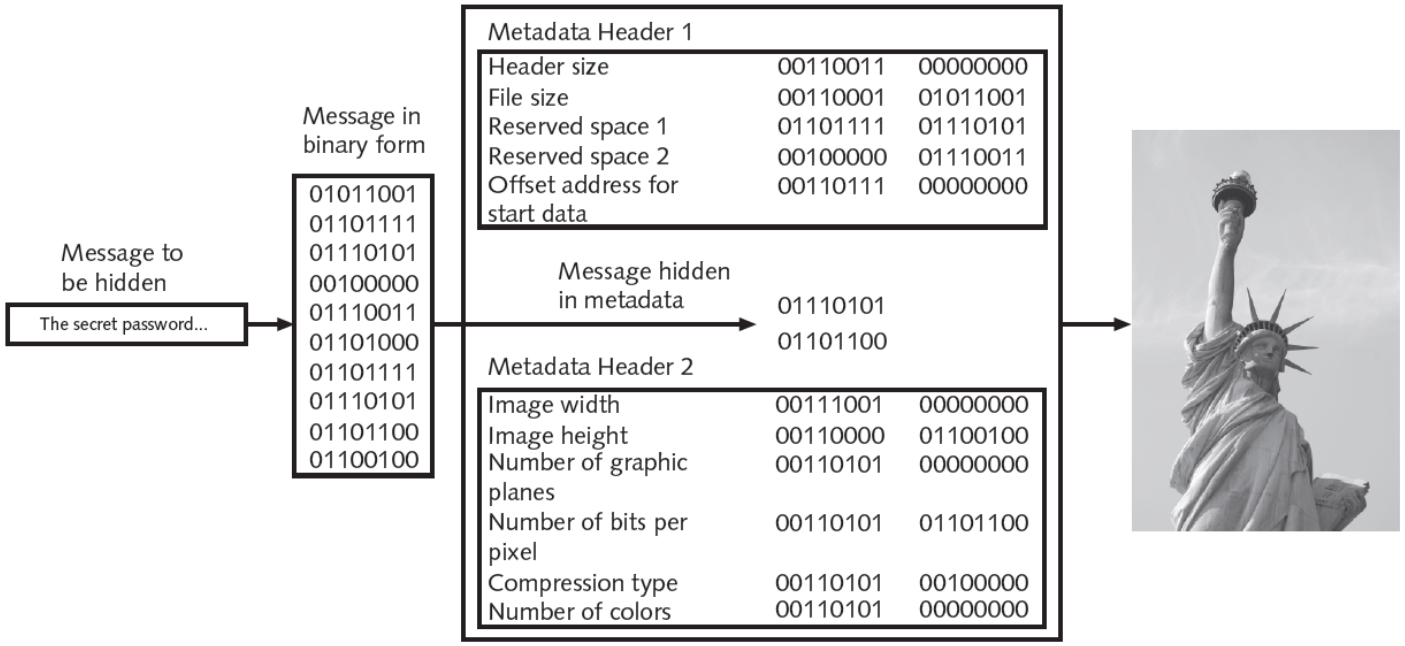
Cryptographie quantique

- Exploite les caractéristiques des objets microscopiques tels que les photons
- Ne dépend pas des problèmes basés sur une difficulté mathématique (de calcul)



Stéganographie

- Cacher l'existence des données
- Fichiers images, audios ou vidéos contenant des messages cachés incorporés
- Diviser les données et les incorporer dans les parties inutilisés des fichiers



Principe de Kerckhoffs (1883)

- L'adversaire connaît tout le système et ses composantes, sauf la clé secrète. Le mécanisme utilisé (l'algorithme) pour déchiffrer est connu de tous même de l'adversaire (moins de vulnérabilités à exploiter en sachant que tout le monde utilise le même mécanisme, i.e. si une vulnérabilité est présente elle sera rapidement détecté).
- Certains experts ne reconnaissent pas le principe de Kerckhoffs et préfèrent cacher l'algorithme en plus de la clé (p.e. certains gouvernements).
- « No security by obscurity »
  - C'est pas parce qu'on le cache que c'est sécuritaire…
  - Lire les anecdotes sur ENIGMA sur Internet